

Secure Baselines

The security of an application environment should be well defined:

- All application instances must follow this baseline
- Firewall settings, patch levels, OS file versions
- May require constant updates

Integrity measurements check for the secure baseline:

- These should be performed often
- Check against well documented baselines
- Failure requires an immediate correction

Establish baselines:

- Foundational security policies

Security baselines are often available from the manufacturer:

- Application developer
- Operating system manufacturer
- Appliance manufacturer

Many operating systems have extensive options:

- There are over 3000 group policy settings in windows 10
- Only some of those are associated with security

Deploy baselines:

We now have established detailed security baselines:

- How do we put them into action?

Deploy the baselines:

- Usually managed through a centrally administered console

May require multiple deployment mechanisms:

- Active Directory group policy, MDM, etc

Maintain Baselines:

Many of these are best practices:

- They rarely change

Other baselines may require ongoing updates:

- A new vulnerability is discovered
- An updated app has been deployed
- New OS is installed

Test and measure to avoid conflicts:

- Enterprise environments are complex

Hardening Targets

No system is secure with the default configurations:

- You need some guidelines to keep everything safe

Hardening guides are specific to the software or platform:

- Get feedback from the manufacturer or Internet interest group
- They'll have the best details

Other general purpose guides are available online

Mobile devices:

Always connected to mobile technologies:

- Phones, tablets, etc.
- Hardening checklists are available from the manufacturers

Updates are critical:

- Bug fixes and security patches
- Prevent any known vulnerabilities

Segmentation can protect data:

- Company and user data are separated

Control with MDM (Mobile device manager)

Workstations:

Desktops and laptops need hardening

Constant monitoring and updates with OS apps and firmware

Automate monthly patches

Connect to a policy management system:

- Active Directory group policy

Remove unnecessary software:

- Limit the threats

Network Infrastructure devices:

Switches routers, etc.:

- You never see them, but they're always there

Purpose built devices:

- Embedded OS, limited OS access

Config authentication:

- Don't use defaults

Check with the manufacturer:

- Security updates
- Not usually updated frequently
- Updates are usually important

Cloud infrastructure:

Secure the cloud management workstation:

- The keys to the kingdom

Least privilege:

- All services, network settings, App rights, perms etc

Configuration. Endpoint detection. And Response (EDR);

- All devices accessing the cloud should be secure

Always have backups:

- Cloud to Cloud (C2C)

Servers:

Many are varied:

- windows, linux etc.

Updates:

- OS updates / service packs, security patches

User accounts:

- Minimum password lengths and complexity
- Account limitations

Network access and security:

- Limit network access

SCADA /ICS:

Supervisory Control and Data Acquisition System (SCADA):

- Large-scale, multi-site Industrial Control System(ICS)

PC manages equipment:

- Power generation, refining, manufacturing equipment
- Facilities, Industrial, energy, logistics

Distributed control systems:

- Real time information
- System control

Requires extensive segmentation:

- No access from the outside

Embedded systems:

Hardware and software designed for a specific function:

- or to operate as part of a larger system

Can be difficult to upgrade:

- Watches and TVs are relatively easy
- Other devices may not be easily modified

Correct vulnerabilities:

- Security patches remove potential threats

Segment and firewall:

- Prevent access from unauthorized users

RTOS (real time operating system):

An operating system with a deterministic processing schedule:

- No time to wait for other processes
- Industrial equipment, automobiles, military environments

Isolate the system:

- Prevent access from the other areas

Run the minimum services:

- Prevent potential for exploit

Use secure communication:

- Protect with a host based firewall

IoT devices:

Heating and cooling, lighting, home automation, wearable tech, etc

Weak defaults:

- IOT manufactures are not security pros
- Change those passwords

Deploy updates quickly:

- Can be a significant security concern

Segmentation:

- Put IoT devices on their own VLAN

Securing Wireless and Mobile

Site surveys:

Determine existing wireless landscape:

- Sample the existing wireless spectrum

Identify existing access points:

- You may not control them

Work around existing frequencies:

- Layout and plan for interference

Plan for ongoing site surveys:

- Things will certainly change

Heat maps are great to illustrate WIFI signal strength

Wireless survey tools:

- Signal coverage
- potential interference
- Built in tools
- 3rd party tools that you can attach to your wireless survey tool
- Spectrum analyzer

Mobile Device Management (MDM):

Manage company-owned and user-owned mobile devices:

- BYOD- bring your own device

Centralized management of the mobile devices:

- Specialized functionality

Set policies on apps, data, camera, etc:

- Control the remote device
- The entire device or partition

Manage access control:

- Force screen locks and pins on these single user devices

BYOD:

Bring your own device or bring your own technology

Employee owns the device:

- Need to meet the companies requirements

Difficult to secure:

- its both home and work device
- How is data protected?
- What happens to the data when a device is sold or traded in

COPE:

Corporate owned, Personally enabled:

- Company buys the device
- Used as both a corporate device

Organization keeps full control of the device:

- similar to company owned laptops and desktops

Information is protected using corporate policies:

- Information can be deleted at any time

CYOD - Choose your own device:

- Similar to COPE, but with the users choice in device

Cellular networks:

Mobile devices:

- Cell phones
- 4G, 5G

V

Separate land into cells:

- Antenna coverages a cell with certain frequencies

Security concerns:

- Traffic monitoring
- Location tracking etc

WIFI devices:

Local network access:

- Local security problems

Same security concerns as other wifi devices

Data capture:

- Encrypt your data

On path attack:

- Modify/monitor data

DOS:

- Frequency interference

Bluetooth:

High speed communication over short distances:

- PAN (personal Area network):

Connects our mobile devices:

- Smartphones, tethering, headsets and headphones, smartwatches etc

Do NOT connect to unknown bluetooth devices:

- There a moral pairing process to prevent unauthorized connections

Wireless Security Settings

Securing a Wireless network:

An Organizations wireless network can contain confidential information:

- Not everyone is allowed access

Authenticate the users before granting access:

- Who gets access to the wireless network?
- Username password, multi-factor authentication

Ensure that all communication is confidential:

- Encrypt all data

Verify the integrity of all communication:

- The received data should be identical to the original data sent
- A message integrity check (MIC)

The WPA2 PSK problem:

WPA2 has a PSK brute force problem:

- Listen to the fairway handshake:
 - Some methods can derive the PSK hash without the handshake
- Capture the hash

With the hash, attacker can brute force the pre shared key (PSK)

This has become easier as technology improves:

- A weak PSK is easier to brute force
- GPU processing speeds
- Cloud based password cracking

Once you have the PSK, you have everyones wireless key:

- There's no forward secrecy

WPA3 and GCMP:

WIFI protected access 3 (WPA3):

- Introduced in 2018

GCMP block cipher mode:

- Galois/Counter mode protocol
- A stronger encryption than WPA2

GCMP security services:

- Data confidentiality with AES (Advanced encryption Standard) protocol
- Message Integrity Check (MIC) with Galois Message Authentication Code (GMAC)

SAE:

WPA3 changes the PSK authentication process:

- Includes mutual authentication
- Creates a shared session key without sending that key across the network

- No more four way handshakes, no hashes, no brute force attacks

Simultaneous Authentication of Equals (SAE):

- A Diffie-Hellman derived key exchange with an authentication component
- Everyone uses a different session key, even with the same PSK
- An IEEE standard - the dragonfly handshake

Wireless authentication methods:

Gain access to wireless network:

- Mobile users
- Temporary users

Credentials:

- Shared password / Pre-shared key (PSK)
- Centralized authentication (802.1X)

Configuration:

- Part of the wireless connection
- Prompted during the connection process

Wireless security modes:

Configure the authentication on your wireless access point / wireless router

Open System:

- No authentication password required

WPA3-Personal /WPA3-PSK:

- WPA2 or WPA3 with a reshared key
- Every uses the same 256 bit key

WPA3-Enterprise / WPA3-802.1X:

- Authenticates users individually with an authentication server (I.e, Radius)

AAA framework:

Identification;

- This is who you claim to be
- Usually your authentication

Authentication:

- prove you are who you say you are
- Password and other authentication factors

Authorization:

- Based on your ID and authentication, what access do you have

Accounting:

- Resources used: login time, data sent, etc.

AAA stands for: Authentication, Authorization, Accounting

RADIUS (Remote Authentication Dial-in User Service):

One of the more common AAA protocols:

- supported on a wide variety of platforms and devices:
- Not just for dial-in

Centralize authentication for users:

- Routers, switches, firewalls
- Server authentication
- Remote VPN access
- 802.1X network access

RADIUS services available on almost any server operating system

IEEE 802.1X:

- Port based Access Control (NAC)
- You don't get access to the network until you authenticate

Used in conjunction with an access database:

- RADIUS, LDAP, TACACS+

EAP:

Extensible Authentication Protocol (EAP):

- an authentication framework

Many different ways to authenticate based on RFC standards:

- Manufacturers can build their own EAP standards

EAP integrates with 802.1X:

- Prevents access to the network until the authentication succeeds

Supplicant - the client

Authenticator - The devices providing or not allowing access

The authentication server - Validates credentials

Application Security

Secure coding concepts:

A balance between time and quality:

- Programming with security in mind is often secondary

Testing, testing, testing:

- The quality Assurance process

Vulnerabilities will eventually be found and exploited

Input validation:

What is the expected input:

- Validate actual vs expected

Document all input methods:

- forms, fields, type

Check and correct all input (normalization) :

- A zipcode should only be X number of characters long with a letter in the X column
- Fix any data with improper input

The fuzzers will find what you missed:

- Dont give them an opening

Secure cookies:

Cookies:

- Information stored on your computer by the browser

Used for tracking, personalization, session management :

- not exe, not generally a security risk
 - Browser will only send it over HTTPS

Sensitive information should not be saved in a cookie:

- This isn't designed to be secure storage

Static code analyzers:

Static Application Security Testing (SAST):

- Help to identify security flaws

Many security vulnerabilities found easily:

- Buffer overflows, database injections, etc.

Not everything can be identified through analysis:

- Authentication security, insecure cryptography, etc
- Don'tt rely on automation for everything

Still have to verify each finding:

- False positives are an issue

Code signing:

An application is deployed:

- User run application executable or scripts

So many security questions:

- Has the application been modified in any way?
- Can you confirm that the application was written by a specific developer?

The application code can be digitally signed by the developer:

- Assymmetric encryption
- A trust CA signs the developers public key

- For internal apps, use your own CA

Sandboxing:

Applications cannot access unrelated resources:

- They play in their own sandbox

Commonly used during development:

- Can be useful production technique

Used in many different deployments:

- VMS
- Mobile devices
- Browser iFrames (inline frames)
- Windows User Account Control (UAC)

Application Security Monitoring:

Realtime information:

- Application usage, access demographics

View blocked attacks:

SQL injection attempts, patched vulnerabilities

Audit the logs:

- Find the information gathering and hidden attacks

Anomaly detection:

- Unusal file transfers
- Increase in client access

4.2 Asset Management

Acquisition/procurement process:

The purchasing process:

- Multistep process for requesting and obtaining good and services

Start with a request from the user:

- usually includes budgeting information and formal approvals

Negotiate with suppliers:

- Terms and conditions

Purchase, invoice, and payment:

- the money part

Assignment/accounting

A central asset tracking system:

- Used by different parts of the org

Ownership:

- Associate a person with the asset
- Useful for tracking a system

Classification:

- type of asset
- Hardware (capital expenditure)
- Software (operating expenditure)

Monitoring / asset tracking:

Inventory every asset;

- Laptops, desktops, servers, routers all that stuff

Associate a support ticket with a device make and model:

- Can be more detailed than a users description

Enumeration:

- List all parts of an asset:
- Like cpu, mouse, keyboard, storage drive etc

Add an asset tag like a barcode , RFID, tracking number anything like that

Media sanitization:

System disposal or decommissioning:

- completely remove data
- No usable information remains

Different use cases;

- Clean a hard drive for future use
- Permanently delete a single file

A one way trip:

- Once its gone its really gone
- No recovery with forensic tools

Reuse the storage media:

- Ensure nothing is left behind

Physical destruction:

Shredder / pulverizer:

- heavy machinery
- Complete destruction

Drill / hammer:

- Quick and easy
- Platters, all the way through

Electromagnetic field:

- Remove the magnetic field

- Destroy hard drive data and renders the hard drive unusable

Incineration;

- Fire

Certificate of destruction:

Destruction is often done by a 3rd party:

- How many drills and degaussers do you have?

Need confirmation that your data is destroyed:

- service should include a certificate

A paper trail of broken data:

- you know exactly what happened

Data retention:

Backup your data:

- How much and where?
- Copies, versions of copies, lifecycle of data, purging old data

Regulatory compliance:

- A certain amount of data backup may be required
- Emails corporate financial data

Operation needs:

- Accidentally deletion
- Disaster recovery

Differentiate by type and application:

- Recover the data you need when you need it